SectraTEK

AI FOR CYBERSECURITY AND DIGITAL FORENSICS · LAB 09

Call the First Responder



When an incident hits, the team calls Sectra. It reads the company's own plan and playbooks, walks the team through the response, and does the parts a model safely can, only with the team's approval.

Daniel Kwaku Ntiamoah Addai · Mobile Threat Research Lead, SectraTEK Lab · AI for Cybersecurity and Digital Forensics

YOUR INSTRUCTOR

Daniel Kwaku Ntiamoah Addai



Mobile Threat Research Lead

SectraTEK Lab

lab.sectratek.com

IN ONE LINE

I study how phones get spied on and tampered with, and build AI tools that help examiners find the evidence.

Mobile threat research
Spyware, stalkerware and device tampering.

AI for investigators
Machine learning that speeds up the search.

Teaching
AI for Cybersecurity and Digital Forensics.

TODAY'S STORY

From a binder nobody opens to a responder on the line

1

The call

An incident hits; the clock starts.

2

Before AI

The plan exists, in a document no one reads mid-crisis.

3

The problem

Under pressure, steps get skipped; a generic bot invents them.

4

The idea

A copilot that knows YOUR plan and playbooks.

5

What it can do

Run, draft, or simulate: one tool per action.

6

The guardrail

Approval for anything real; simulated, cited, logged.

7

A drill

Ransomware, walked end to end.

8

Your lab

Bring your own playbooks and artifacts.

Practical runs in Google Colab with a free hosted Groq model. Nothing is installed on your computer.

THE CALL

09:41, and something is wrong

A finance workstation is behaving strangely: files renamed, a ransom note on the desktop, backups failing. The team has minutes, not hours. What happens next?



The clock is running

Every minute of hesitation is more encrypted files or more data gone.



People, under stress

The responders are smart but rushed, and they do not do this every day.



A plan they wrote

There IS an IR plan and there ARE playbooks: calm, correct, and unread.

BEFORE AI

The plan lives in a binder

1. Find the right playbook	Open the IR document, scroll to the section for this kind of incident.
2. Read the steps	Classify severity, isolate, notify, collect, contain, in the right order.
3. Write the notifications by hand	Draft the management note from the template, each time, under pressure.
4. Recall the commands	Remember the exact collection and containment commands and paths.

IT WORKS, IF THE RIGHT EXPERT IS IN THE ROOM, CALM, AT 3 A.M.

The process is sound. The failure mode is human: the person who remembers every step is on leave, or rattled, or reading the binder for the first time tonight.

THE PROBLEM

Skip a step, or let a chatbot invent one

The human gap

under pressure

Steps get skipped or done out of order. Management is told too late. Evidence is destroyed by powering a machine off.

The naive-AI gap

generic advice

Ask a plain chatbot “what do we do?” and it gives textbook incident response, not what YOUR plan says, not your contacts, not your templates.

Both fail the same way: the response is not anchored to the plan the company actually agreed on.

THE IDEA

A responder that knows YOUR plan

Sectra First Responder is a copilot whose knowledge is the company's own IR plan and playbooks. The team tells it what they think is happening; it tells them what the plan says, then offers to do the parts it safely can, never without approval.

Grounded in your documents

It answers from the plan and playbooks you load, and cites the section every time.

Walks the team, one step at a time

A calm conversation: what is happening, what next, what it can do for you.

Offers, never overrides

It proposes the next action and waits for the team's yes; people stay in command.

WHAT IT CAN DO

Run, draft, or simulate

For every action a playbook calls for, we decided what a language model can safely do, then built one tool for it. Every tool is one of three kinds:

RUN

it does it

A local, read-only or analytical step with no outside effect.

classify the incident · build a timeline · extract & check indicators · write the after-action report

DRAFT

you run it

It cannot touch production, so it writes ready-to-run content for a human.

the notification text · the exact collection, containment, eradication and recovery commands

SIMULATE

approval first

A real side effect, so only after the team approves, and even then it is logged, not real.

notify management · open a ticket · page on-call · block an indicator / isolate a host

THE TOOLBOX

One tool per action, grouped by phase

Know the plan + ISMS

`playbooks: list / search / read, classify_incident · ISMS: lookup_asset, list_assets, lookup_risk, check_policy`

Notify & coordinate

`draft_notification · notify, open_ticket, page_oncall`

Guide the work

`recommend_collection / containment / eradication / recovery`

Contain

`contain: isolate_host · disable_account · block_ioc`

Analyse evidence

`read / search / run_sql · build_timeline · extract & check IOCs`

Close out

`after_action_report from the action log`

The model picks the tool and fills in the arguments; our loop runs it and feeds back what it saw.

THE GUARDRAIL

Nothing real happens without a yes

Human in the loop

A side-effect tool refuses unless Sectra passes approved = true; its instructions say to do that only after your yes.

Simulated, never real

Even approved, a “send” or “block” is logged to an action log: no real email, no real firewall change.

Grounded and cited

Every instruction comes from the plan or a playbook, and names the section so the team can verify it.

Evidence check

Code checks every reply: a tool ran; every file, IP, PID, and 0x address appears in tool output; no unrun tool is cited. Two tries, then UNVERIFIED.

Reasoning in the open

Each thought, tool, and evidence check shows in the trace; every simulated action lands in the action log.

WHY IT MATTERS

An incident is the worst time for a confident machine acting on its own. The copilot speeds up the thinking and the paperwork; the people keep every decision that changes a system, declares a breach, or tells a customer.

CHECK IT YOURSELF

The AI, not the code, decides that you said yes, so read the action log. The evidence check catches invented details, not a wrong reading of real evidence.

A DRILL

Ransomware, walked end to end

1	Classify	RUN	Matches the ransomware playbook, SEV-1; gives the first step, citing it.
2	Notify	DRAFT → approve	Drafts the management note from the template; on “approve”, logs a simulated send.
3	Collect	DRAFT	Lists the exact tools, commands and paths to preserve evidence.
4	Analyse	RUN	Timelines the log, pulls indicators, flags exfil-sync.example on the watch-list.
5	Contain	SIMULATE → approve	On approval, simulates isolating the host and blocking the indicator.
6	Close out	RUN	Writes the after-action report from the action log.

PRACTICAL

Your turn, in the browser

1	**Open in Colab**	ir_chatbot_ui.ipynb (7 steps) or the Jupyter version (9 steps). Each step gives its Purpose, Input, How it works, and Output.
2	**Paste a free key**	Your free Groq key (the same as Labs 01-06), or run a local Ollama.
3	**Load the plan**	The notebook writes a sample IR plan, playbooks, ISMS policies, and watch-list. Or drop in your own.
4	**Run the drill**	Report the incident, then draft, approve, collect, analyse, contain, and close out.
5	**Feed it evidence, read the log**	Give it the two sample evidence files to timeline and check. Then read the action log: every simulated action should match a yes you gave.

SectraTEK

Make the plan answer the phone.

An IR copilot turns the binder into a responder on the line: it tells the team what the plan says, does what it safely can, and never takes a real action without a human's yes.

